

Kryptografie × autentizace (primitiva a jejich použití)

Kryptografie × autentizace

Spojení

[[okruhy/44-smerovani-zabezpeceni-siti|Okruh 44]] staví **primitiva** (co kryptografie umí), [[okruhy/37-webova-rozhrazeni-autentizace|okruh 37]] je **aplikuje** (jak se to používá na webu), [[okruhy/42-sluzby-aplikacni-vrstvy|okruh 42]] je používá pro e-mail/HTTPS:

- **44** — symetrická/asymetrická šifra, kryptografický **hash**, **digitální podpis**, **certifikáty** a řetězec důvěry, integrita, ochrana proti přehrání.
- **37** — **JWT** (podepsaný token), **TLS** (výměna klíčů + šifrování), cookies, **OAuth**, SSO.
- **42** — **PGP/S-MIME** (zabezpečení obsahu e-mailu), HTTPS.

Kde se potkávají

Tytéž pojmy (veřejný/soukromý klíč, hash, podpis) se objevují v definici (44) i v každém konkrétním mechanismu (37, 42).

Průřezový poznatek

Abstraktní primitiva z 44 se mapují 1:1 na webové mechanismy z 37.¹

- **Digitální podpis** (44: hash □ šifruj privátním klíčem) = **jak JWT dokazuje, že nebyl pozměněn** (37). Token je *podepsaný*, ale **čitelný** — proto „base64 ≠ šifrování”.
- **Přechod asym □ sym kvůli výkonu** (44) = **přesně TLS handshake** (37): asymetricky se dohodne klíč, dál se jede symetricky.
- **Certifikát + řetězec důvěry ke kořenové CA** (44) = **jak prohlížeč důvěřuje HTTPS serveru** (37).
- **PGP** (42) je tentýž postup (hash+podpis, sym. klíč zašifrovaný veřejným klíčem příjemce) aplikovaný na tělo e-mailu.

Klíčový rozdíl, který musíš udržet stejně v 44 i 37: **hash** ≠ **šifra** ≠ **podpis** (integrita × důvěrnost × autenticita).²

Napětí a kompromisy

- **Autentizace × autorizace**: 37 výslovně upozorňuje, že HTTP hlavička Authorization špatně pojmenovává **autentizaci** (ověření identity), zatímco autorizace = povolení operace. Stejná dvojice pojmů, snadno zaměnitelná.
- **Bezpečnost × výkon**: delší klíče (44) = bezpečnější, ale pomalejší; proto se asym. použije jen na ustavení klíče a dál symetricky (37, TLS). RSA 15360 b je „prakticky nepoužitelné” — proto ECC.

¹inferred

²inferred

Otevřené otázky

- Jak se liší záruky **session+cookie** vs. **JWT** vs. **OAuth** z pohledu útoku odcizením tokenu (37) a co tomu brání kryptograficky (44)?

Související

- [[okruhy/44-smerovani-zabezpeceni-siti]]
- [[okruhy/37-webova-rozhrani-autentizace]]
- [[okruhy/42-sluzby-aplikacni-vrstvy]]